Jenaplan-Kompetenzmanager

Sicherheit und Verschlüsselung

Schutzstand, Grenzen und Verantwortlichkeiten

Zielgruppe Lehrkräfte, technische Betreuung und Releaseverantwortliche	**Dokumentstand** 27. Juli 2026
Version 0.3.0 · Build 302	**Status** Interne Pilot- und Releasevorbereitung, kein öffentlicher Release

Lokale Desktop-App · macOS auf Apple Silicon

Inhaltsverzeichnis

Die Kapitel folgen der Bedienung und den wichtigen Kontrollpunkten.

1. Überblick 3
2. Heute aktiv geschützt 3
3. Aktuelle Datenhaltung 4
4. Verschlüsselungsstatus 4
5. Schlüsselarchitektur in verständlicher Form 5
6. Backup und Restore 5
7. Bedrohungsmodell 6
8. Verantwortlichkeiten der Schule 7
9. Plattform- und Releasegrenzen 7
10. Offene Schritte 8

Stand: 27. Juli 2026 Geltung: Produktversion 0.3.0, vorbereiteter Build 302 Status: interne Pilot- und Releasevorbereitung, kein öffentlicher Release

Dieses Dokument beschreibt den tatsächlich aktiven Schutzstand und die bewusst noch nicht aktivierte Verschlüsselungsintegration. Es ist keine Datenschutzfreigabe, keine Rechtsberatung und keine Aussage „DSGVO-konform“ oder „vollständig sicher“.

1. Überblick

Der Jenaplan-Kompetenzmanager ist eine lokale Desktop-App für macOS auf Apple Silicon (arm64). Er überträgt keine fachlichen Daten in eine Cloud und bindet keine KI-Dienste ein. Schülerdaten, Beobachtungen, Anhänge, Berichte, Lernentwicklungsgespräche und PDF-Ausgaben haben deshalb einen hohen Schutzbedarf.

Der für 0.3.0 / Build 302 vorgesehene interne macOS-Build wird ad-hoc signiert und nicht notarisiert. Es gibt keine Windows-Freigabe, keinen öffentlichen Stable-Release und keinen Stable-Appcast. Ein konkretes DMG, eine Prüfsumme und der zugehörige Produkt-Commit entstehen erst beim späteren Clean-Build; sie werden hier nicht vorweggenommen.

2. Heute aktiv geschützt

Im normalen Produktpfad sind folgende Schutzfunktionen aktiv:

Sicherheit

- lokales Passwort mit erster Passwortanlage, Bestätigung und Passwortänderung;
- Recovery-Codes als erster Wiederherstellungsweg;
- optionales Gerätecredential im macOS-Schlüsselbund für die Komfortanmeldung;
- optionales Touch ID bei erfüllten Voraussetzungen;
- sichtbare Gründe, wenn Touch ID nicht eingerichtet, nicht verfügbar oder vorübergehend gesperrt ist;
- immer verfügbarer Passwort-Fallback;
- automatische App-Sperre nach Inaktivität oder Ruhezustand sowie Jetzt sperren;
- betreuter Support-Reset mit zeitlich begrenztem, installationsgebundenem Code und vorherigem Sicherheitsbackup;
- geprüfter lokaler ZIP-v1-Backup- und Restorepfad;
- getrennte lokale Runtime-Bereiche, restriktive Dateirechte und kein Zugriff auf den fachlichen Bestand vor erfolgreicher Anmeldung.

Die App-Sperre schützt die Oberfläche vor unbefugter Nutzung im laufenden Alltag. Sie ist ausdrücklich keine Verschlüsselung der fachlichen Datenbank, verwalteter Dokumente oder ZIP-v1-Backups.

Signierung und Updates

Der erwartete interne macOS-Build wird ad-hoc signiert. Das hilft bei der Integritätszuordnung des erzeugten Artefakts, ersetzt aber weder Developer ID noch Apple-Notarisierung. Es ist kein öffentlicher Updatekanal aktiv. Signierte Updateartefakte werden deshalb nicht als aktive Schutzfunktion für den normalen Produktbetrieb behauptet.

3. Aktuelle Datenhaltung

Die App hält ihre Daten lokal und getrennt vom App-Bundle:

- Die fachliche SQLite-Datenbank enthält den fachlichen Bestand.
- Verwaltete Dokumente und finale Bericht- und LEG-PDFs liegen im lokalen App-Datenbereich.
- Ein separater Security Store enthält Anmelde- und Security-Metadaten.
- Lokale Backups werden bewusst an einem von der Lehrkraft gewählten, schulisch freigegebenen Ort angelegt.
- Frei exportierte Entwurfs-PDFs und andere bewusst abgelegte Ausgaben liegen außerhalb der App und müssen wie vertrauliche Schulunterlagen behandelt werden.

Dieses Dokument nennt absichtlich keine Entwicklerpfade, Secrets, Keychain- Einträge oder konkrete lokale Kennungen. Technische Betreuung soll nur die zuständige lokale Datenablage nach der jeweils freigegebenen Installationsanleitung verwalten.

4. Verschlüsselungsstatus

Die Security- und Verschlüsselungsfoundations sind implementiert und getestet. Dazu gehören SQLCipher für eine Datenbank, verschlüsselte Dokumentcontainer, ein verschlüsselter Backupcontainer sowie kontrollierte Migrations- und Recoverykonzepte.

Diese Foundations sind im Produktstand 0.3.0 jedoch **nicht** standardmäßig aktiv:

> **Hinweis**
>
> - Der normale Pfad verwendet weiterhin SQLite, die bestehende lokale Dokumentablage und ZIP-v1-Backups.
> - Das Security-Integrationsgate ist standardmäßig aus und besitzt keine Nutzeroberfläche.
> - Es akzeptiert ausschließlich besonders markierte technische Testroots, nicht normale Datenroots, Pilotbestände oder Produktdaten.
> - Bestehende Pilot- und Produktdaten werden nicht automatisch zu SQLCipher migriert.
> - Dokumente und produktive Backups werden nicht still in verschlüsselte Container überführt.
> - Eine aktive Produktdatenverschlüsselung wird weder behauptet noch automatisch aktiviert.

Die vorhandenen Container und der Migrationscode sind damit ein getesteter Vorbereitungsstand, keine Nutzerfunktion. Kontrollierte Produktmigration, Pilotaktivierung der Verschlüsselung und eine verständliche Recovery-Nutzerführung bleiben offene, gesondert freizugebende Schritte.

5. Schlüsselarchitektur in verständlicher Form

Die aktive Anmeldung und die vorbereitete Verschlüsselungsarchitektur haben unterschiedliche Aufgaben.

- Das lokale Passwort authentifiziert die Lehrkraft; es ist nicht der Datenbankschlüssel.
- Ein Plattform-Credential im macOS-Schlüsselbund schützt in der vorbereiteten Architektur den Data Master Key (DMK).
- Von diesem DMK abgeleitete, getrennte Schlüssel sind für Datenbank, Dokumente und Backups vorgesehen.
- Passwortwechsel und Support-Reset ändern das Passwort und die Anmeldeinformationen, ersetzen aber nicht den DMK.
- Schlüssel, Passwörter, Recovery-Codes und vollständige Reset-Codes gehören weder in Logs noch in fachliche Backups.

Diese Architektur ist absichtlich nur bis zu der Tiefe beschrieben, die für schulische technische Betreuung erforderlich ist. Kryptografische Formate, Schlüsselhüllen, Ableitungen, Authentisierung und Migrationszustandsautomaten sind in den bestehenden technischen ADRs, insbesondere ADR-075 bis ADR-093 und ADR-088, dokumentiert. Dieses Dokument dupliziert diese Details nicht.

6. Backup und Restore

Der produktive Backup- und Restorepfad verwendet ZIP-v1.

Backup

Ein Backup wird bewusst ausgelöst, erstellt einen kontrollierten Snapshot und wird geprüft. Der Status zeigt, ob eine Sicherung bestätigt werden konnte. Ein Backup enthält den fachlichen Bestand und die registrierten verwalteten Dateien, aber keine Passwörter, Recovery-Codes, gespeicherte Anmeldung, Touch-ID-Einstellung oder Security-Metadaten.

Restore

Eine Wiederherstellung beginnt mit einer Prüfung und einer datensparsamen Vorschau. Erst nach einer klaren Bestätigung wird Restore-Staging vorbereitet und nochmals geprüft. Vor dem fachlichen Austausch erzeugt der Ablauf ein Sicherheitsbackup.

Ein separater Restore-Worker übernimmt danach den kontrollierten Austausch. Die App beendet sich vollständig und startet kontrolliert neu. Anschließend ist eine erneute Anmeldung erforderlich. Scheitert die sichere Auflösung oder der Start des Workers, bleibt der bisherige aktive Bestand unverändert und die App zeigt eine Fehlermeldung an.

Grenzen

> **Warnung**
>
> ZIP-v1 ist lokal und nicht als verschlüsselter Backupcontainer deklariert. Ein verschlüsseltes Backup-v2 existiert nur als nicht aktivierte Foundation. Schulen sollen daher zusätzlich externe, schulisch geregelte Sicherungen vorhalten - insbesondere vor Updates, Migrationen, Gerätewechseln oder Supportmaßnahmen.

7. Bedrohungsmodell

Gegen welche Risiken dieser Stand vorbereitet ist

Mit einer später kontrolliert aktivierten Verschlüsselung soll insbesondere besser geschützt werden gegen:

- kopierte Datendateien;
- kopierte Backups;
- verlorene Geräte;
- manipulierte oder beschädigte Artefakte;
- unterbrochene Migrationen und Wiederherstellungen.

Heute helfen Passwort, App-Sperre, Schlüsselbund, Touch ID, lokale Dateirechte, Backupprüfung, Prüfsummen und kontrollierte Restore-Schritte gegen Fehlbedienung und gegen einen Teil der unbefugten Nutzung am regulären Arbeitsplatz. Sie sind kein Ersatz für aktive Datenverschlüsselung.

Was nicht vollständig abgedeckt ist

Weder der aktuelle noch ein später verschlüsselter lokaler Produktpfad schützt vollständig gegen:

- Malware unter demselben macOS-Benutzerkonto;
- Speicheranalyse eines laufenden Prozesses;
- Keylogger;
- Screenshots;
- hochprivilegierte lokale Angreifer;
- eine garantierte physische Löschung von SSD-Daten.

Ein verlorenes Gerät bleibt ein meldepflichtiger Sicherheitsvorfall. Die vorbereitete Verschlüsselung reduziert dieses Risiko erst nach einer kontrollierten, nachweisbaren Produktaktivierung.

8. Verantwortlichkeiten der Schule

Schule, technische Betreuung und Lehrkräfte tragen gemeinsam Verantwortung für den sicheren Betrieb:

- Nur schulisch freigegebene Geräte und sichere lokale Benutzerkonten einsetzen.
- macOS-Gerätesperre sowie FileVault nach Schulvorgabe aktivieren.
- Keine gemeinsamen Benutzerkonten verwenden.
- Externe Backups regelmäßig erstellen, prüfen und nach Schulvorgabe aufbewahren.
- Keine Schülerdaten in Screenshots, Testdaten, Tickets oder frei zugängliche Ablagen übernehmen.
- Exportierte und finale PDFs nur über sichere schulische Wege weitergeben.

Technische Betreuung unterstützt bei Installationsfreigabe, Recovery und Sicherungsstrategie. Sie kennt nicht automatisch das Lehrkraftpasswort und erhält durch einen Support-Reset keinen Zugang zu den fachlichen Daten.

9. Plattform- und Releasegrenzen

Für 0.3.0 / Build 302 gilt:

- ad-hoc signiert;
- nicht notarisiert;
- Apple Developer ID und Notarisierung offen;
- macOS arm64 als Zielplattform;
- Windows ungeprüft, kein DPAPI-Produktpfad;
- keine öffentliche Stable-Freigabe;
- kein Stable-Appcast;
- keine Aussage über einen bereits erzeugten Build-302-Datenträger.

> **Warnung**
>
> Gatekeeper-Hinweise werden ausschließlich über den kontrollierten macOS-Weg für die konkrete interne App freigegeben. Gatekeeper darf nicht global deaktiviert werden.

10. Offene Schritte

Folgende Arbeiten sind bewusst nicht Teil dieses Dokumentations- und Build-302-Vorbereitungsstands:

- kontrollierte Produktmigration bestehender Fachdaten;
- Pilotaktivierung und Abnahme der Verschlüsselung;
- verständliche Recovery-Nutzerführung für verschlüsselte Bestände;
- Windows- und DPAPI-Implementierung samt echter E2E-Abnahme;
- Apple Developer ID, Notarisierung und die zugehörigen Gatekeeper-Nachweise;
- reale Power-Loss-Abnahme auf Zielhardware;
- Freigabe eines öffentlichen Stable-Release.

Bis zu diesen Nachweisen sind die Datenverschlüsselungsfoundations keine aktive Produktfunktion und der Stand ist nicht als vollständig sicher oder datenschutzrechtlich vollständig freigegeben zu verstehen.

Bei Verdacht oder Datenverlust

1. Verlust eines Geräts, unerwartete Passwort- oder Reset-Ereignisse und Verdacht auf Manipulation unverzüglich melden.
2. Datenbereiche nicht manuell verschieben, löschen oder mit Fremdwerkzeugen bearbeiten, solange ein Backup, Restore oder Support-Reset läuft.